

HOW TO SECURE OT, ICS, AND SCADA ENVIRONMENTS

A practical guide to industrial cybersecurity, safety, resilience, architecture, monitoring, incident response, and governance

Alberto (Al) Leiva

Version 1.0 - July 2026

CC BY-NC-SA 4.0

Purpose and responsible-use notice

This manual provides defensive guidance for organizations that own or operate operational technology. OT changes can affect physical processes, worker safety, public safety, product quality, and environmental conditions. All testing, scanning, configuration changes, and incident actions must be authorized and coordinated with operations, engineering, safety, and equipment owners.

Safety before security. *If a cybersecurity action could destabilize a physical process, stop and obtain operational approval before proceeding.*

Table of contents

- 1. Understanding OT, ICS, and SCADA
- 2. Why OT security differs from IT security
- 3. Governance and shared accountability
- 4. Asset inventory and system context
- 5. Risk assessment and safety integration
- 6. Secure architecture, zones, and conduits
- 7. Identity and access management
- 8. Remote access and third-party support
- 9. Network security and industrial protocols
- 10. Secure configuration and change control
- 11. Vulnerability and patch management
- 12. Endpoint, server, and engineering-workstation security
- 13. Backup, recovery, and resilience
- 14. Monitoring and detection
- 15. Threat-informed defense with MITRE ATT&CK for ICS
- 16. Incident response in OT
- 17. Ransomware and destructive-event preparation
- 18. Supply-chain and vendor risk
- 19. Cloud, IIoT, edge, and wireless security
- 20. Physical security and environmental controls
- 21. Compliance, evidence, and metrics
- 22. 30/60/90-day implementation roadmap
- 23. Checklists and sample artifacts
- 24. Glossary and official references

1. Understanding OT, ICS, and SCADA

- Operational technology includes systems and devices that monitor or control physical processes.
- Industrial control systems may include distributed control systems, programmable logic controllers, safety instrumented systems, remote terminal units, human-machine interfaces, historians, engineering workstations, and field devices.
- SCADA commonly supports geographically distributed monitoring and control, such as electric, water, pipeline, transportation, and environmental systems.
- Document the physical consequence of every critical digital function.

2. Why OT security differs from IT security

- Safety, process stability, reliability, and availability often take priority over rapid security changes.
- Legacy devices may have long service lives, limited computing resources, proprietary protocols, and unsupported operating systems.
- Active scanning, aggressive testing, automatic remediation, or unplanned reboots can interrupt production or create unsafe conditions.
- Recovery may require engineering validation, physical inspection, calibration, and controlled restart sequences.
- Security decisions must involve operations and engineering rather than being imposed by IT alone.

3. Governance and shared accountability

- Define executive ownership for OT cyber risk.
- Create an OT security steering group including operations, engineering, safety, IT, security, legal, procurement, and business continuity.
- Assign system owners, asset owners, network owners, safety owners, and incident decision authority.
- Establish approved standards for architecture, access, remote support, logging, backups, change management, and incident response.
- Document risk acceptance authority and exception expiration dates.

4. Asset inventory and system context

- Inventory hardware, software, firmware, operating systems, controllers, network devices, virtual systems, radios, sensors, actuators, and safety systems.
- Record manufacturer, model, serial number, firmware, physical location, process function, owner, network address, dependencies, criticality, support status, and backup method.
- Use passive discovery where possible and validate results with engineering documentation and physical inspection.
- Maintain network diagrams, data flows, process dependencies, and an approved baseline.
- Identify unknown, unmanaged, unsupported, and temporary assets.

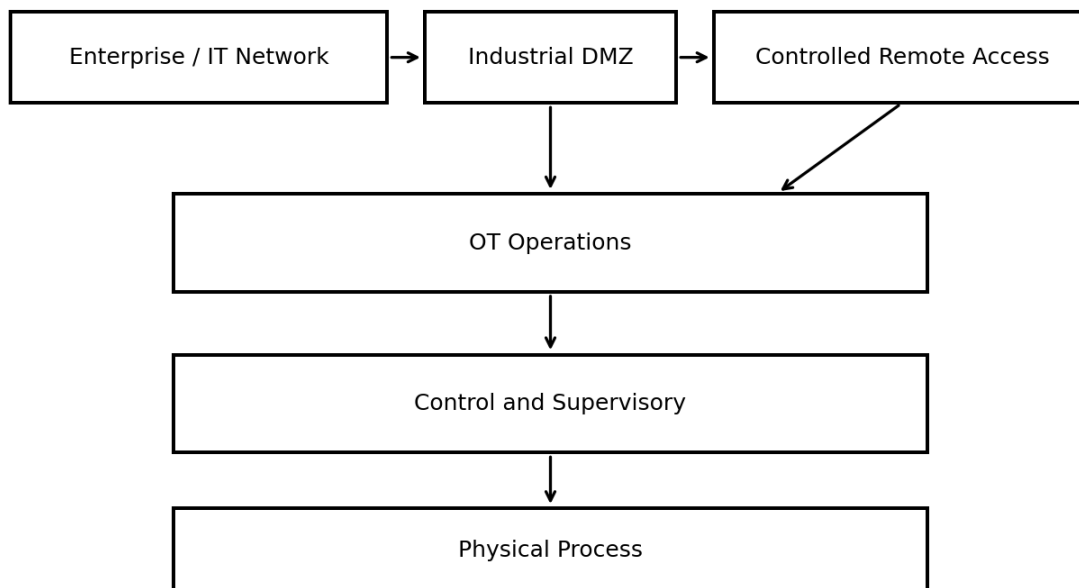
5. Risk assessment and safety integration

- Define the process, mission, safety, environmental, quality, financial, and public-service consequences of failure.
- Model cyber events that could cause loss of view, loss of control, manipulation of control, denial of service, unsafe state, or loss of protection.
- Evaluate threats, vulnerabilities, existing safeguards, likelihood, consequence, and recoverability.
- Integrate cybersecurity risk with process hazard analysis, safety reviews, business impact analysis, and enterprise risk management.
- Prefer risk treatments that reduce cyber exposure without weakening safety or operational reliability.

6. Secure architecture, zones, and conduits

- Group assets into zones according to function, criticality, trust, and required security level.
- Use conduits with explicit communication rules between zones.
- Separate enterprise IT, industrial DMZ, OT operations, control, safety, and field networks.
- Minimize direct connections and prevent uncontrolled Internet access from control zones.
- Use firewalls, data diodes, secure gateways, jump hosts, and application proxies where appropriate.
- Document every cross-zone flow, owner, protocol, direction, purpose, and monitoring requirement.

Segmented OT architecture using zones and conduits



Every connection should have an owner, purpose, authentication, monitoring, and documented rules.

7. Identity and access management

- Use named accounts and eliminate shared administrator credentials where technically possible.
- Separate operator, engineer, maintenance, vendor, and security roles.

- Use multifactor authentication at remote-access, jump-host, VPN, and privileged-management boundaries.
- Apply least privilege and time-limited access.
- Protect service accounts and machine identities; rotate credentials carefully through approved change procedures.
- Review access after job changes, contract completion, incidents, and system decommissioning.

8. Remote access and third-party support

- Prohibit unmanaged direct remote access to controllers and engineering systems.
- Require approved VPN or zero-trust access, MFA, a controlled jump host, session logging, and time-limited authorization.
- Enable access only during approved maintenance windows when practical.
- Require the vendor to identify the person, purpose, systems, expected commands, and duration.
- Monitor sessions and terminate inactive access.
- Maintain an emergency method to disable all remote access without disrupting safe operations.

9. Network security and industrial protocols

- Use default-deny rules between security zones.
- Permit only required source, destination, protocol, port, and direction.
- Understand that many industrial protocols were not designed with strong authentication or encryption.
- Use protocol-aware monitoring and industrial firewalls where appropriate.
- Protect time synchronization, name resolution, routing, and management services.
- Disable unused switch ports, services, wireless interfaces, and vendor backdoors.
- Test network changes in a representative environment before production.

10. Secure configuration and change control

- Create approved secure baselines for controllers, HMIs, servers, workstations, network devices, and safety systems.
- Disable unnecessary services and default accounts.
- Use application allowlisting where supported and operationally safe.
- Require peer review, operational approval, backups, rollback plans, and post-change validation.
- Record logic changes, firmware changes, set-point changes, account changes, and network-rule changes.
- Use cryptographic integrity checking or version control for critical configurations and control logic.

11. Vulnerability and patch management

- Track vendor advisories, CISA alerts, support status, known exploited vulnerabilities, and compensating controls.

- Do not patch solely because a vulnerability score is high; consider exposure, exploitability, safety, process impact, and recovery options.
- Test patches and firmware in a representative environment.
- Schedule maintenance with operations and create backups and rollback plans.
- Use segmentation, allowlisting, virtual patching, monitoring, and access restrictions when immediate patching is unsafe.
- Document accepted risk and review it periodically.

12. Endpoint, server, and engineering-workstation security

- Use dedicated engineering workstations for critical systems.
- Restrict email, web browsing, personal software, and general office use on OT endpoints.
- Use removable-media controls, malware scanning kiosks, and approved transfer procedures.
- Protect local administrator access and disable unnecessary accounts.
- Deploy endpoint protection only after compatibility and performance validation.
- Maintain offline installers, licenses, drivers, configurations, and recovery media.

13. Backup, recovery, and resilience

- Back up controller logic, HMI projects, historian configurations, server images, network configurations, certificates, licenses, recipes, and critical data.
- Keep protected offline or immutable copies.
- Test restoration with engineering and operations.
- Document dependency order and safe restart procedures.
- Maintain spare devices, approved firmware, configuration media, and vendor contacts.
- Exercise manual operation or degraded-mode procedures where feasible.

14. Monitoring and detection

- Collect network, firewall, remote-access, identity, endpoint, server, historian, and controller events according to system capability.
- Use passive OT network monitoring and protocol-aware analytics.
- Baseline normal communications, engineering activity, logic downloads, firmware updates, new devices, and remote sessions.
- Alert on new assets, unexpected protocols, changes to controller logic, disabled protections, unusual commands, and cross-zone traffic.
- Ensure detections are reviewed by personnel who understand both cybersecurity and the physical process.

15. Threat-informed defense with MITRE ATT&CK for ICS

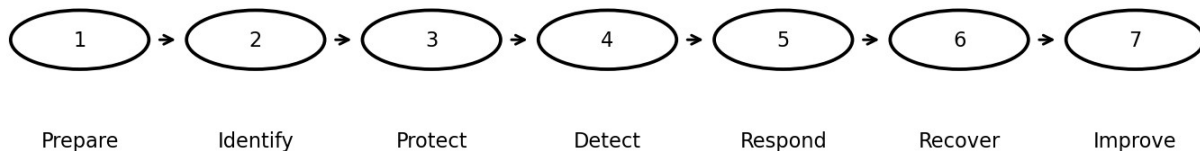
- Use ATT&CK for ICS to understand adversary goals and observed techniques in industrial environments.

- Map likely techniques to available telemetry, preventive controls, detections, response actions, and recovery procedures.
- Prioritize scenarios relevant to the organization's sector, architecture, and threat exposure.
- Do not treat ATT&CK as a compliance checklist.
- Use tabletop exercises and detection validation rather than unsafe live techniques on production control systems.

16. Incident response in OT

- Create an OT-specific incident response plan integrated with safety, operations, engineering, physical security, legal, communications, and enterprise response.
- Define who may isolate a network, stop a process, disable remote access, change controller logic, or initiate shutdown.
- Preserve logs, configurations, controller state, network captures, and physical evidence.
- Contain carefully; disconnecting a device may remove visibility or place the process in an unsafe state.
- Use a controlled recovery sequence and verify process integrity before returning to normal operation.
- Conduct lessons learned and update diagrams, controls, playbooks, and training.

OT security and resilience lifecycle



Security must preserve physical safety, reliability, and process continuity.

17. Ransomware and destructive-event preparation

- Segment OT from enterprise networks and restrict administrative trust paths.
- Protect backups and recovery accounts from the same compromise path.
- Prepare for loss of identity services, virtualization, file shares, remote access, historians, and engineering workstations.
- Identify minimum viable operations and manual alternatives.
- Exercise communications when corporate email and collaboration tools are unavailable.
- Do not connect unverified restored systems back to OT.

18. Supply-chain and vendor risk

- Assess equipment manufacturers, integrators, maintenance providers, software vendors, managed services, cloud services, and remote-support providers.
- Require secure development, vulnerability disclosure, update integrity, support commitments, incident notification, and controlled remote access.
- Verify firmware, software, and configuration sources.
- Track unsupported products and replacement plans.
- Evaluate subcontractors and fourth parties that can access or influence the environment.

19. Cloud, IIoT, edge, and wireless security

- Inventory cloud-connected sensors, gateways, analytics, digital twins, remote telemetry, cellular modems, and wireless networks.
- Separate cloud management from direct process control where possible.
- Use strong device identity, certificate lifecycle management, encrypted communications, and controlled outbound connections.
- Validate fail-safe behavior if cloud or communications services are unavailable.
- Protect update mechanisms and edge-management platforms.
- Assess data residency, privacy, vendor access, and dependency on external services.

20. Physical security and environmental controls

- Control access to control rooms, cabinets, network closets, field enclosures, and portable engineering equipment.
- Monitor tampering, unauthorized connections, open cabinet doors, and device replacement.
- Protect power, cooling, fire suppression, water, environmental monitoring, and backup generation.
- Coordinate cyber and physical investigations.
- Treat unattended field sites and remote substations as higher-exposure environments.

21. Compliance, evidence, and metrics

- Maintain evidence of inventories, diagrams, risk assessments, approvals, access reviews, backups, restoration tests, changes, vulnerabilities, training, exercises, incidents, and remediation.
- Map controls to NIST CSF 2.0, NIST SP 800-82 Rev. 3, ISA/IEC 62443, sector requirements, and organizational policy.
- Track risk reduction, not only activity counts.
- Useful metrics include unmanaged assets, unsupported assets, remote-access exceptions, overdue critical findings, restoration success, detection coverage, and exercise results.
- Clearly identify NIST SP 800-82 Rev. 4 as pre-draft work rather than current final guidance.

22. 30/60/90-day implementation roadmap

- Days 1-30: establish ownership, identify critical processes, inventory priority assets, document remote access, validate backups, and review major IT-to-OT pathways.
- Days 31-60: create zones and conduits, reduce excessive access, baseline network traffic, establish vulnerability triage, and write OT incident playbooks.
- Days 61-90: test restoration, exercise ransomware and loss-of-view scenarios, validate detections, formalize supplier requirements, and create executive metrics.

23. Checklists and sample artifacts

Production readiness checklist

- ☐ Critical process and safety consequences documented
- ☐ Asset inventory and network diagrams validated
- ☐ Owners and incident authority assigned
- ☐ Zones and conduits approved
- ☐ Remote access controlled and monitored
- ☐ Named accounts, MFA boundaries, and privileged access reviewed
- ☐ Backups protected and restoration tested
- ☐ Vulnerability triage process operational
- ☐ Secure baselines and change control in place
- ☐ Passive monitoring and high-value detections enabled
- ☐ OT incident plan and safe containment decisions documented
- ☐ Ransomware and loss-of-view exercise completed
- ☐ Supplier and unsupported-product risks tracked
- ☐ Manual or degraded operation procedures reviewed
- ☐ Executive risk acceptance recorded

Sample OT asset inventory fields

Field	Example
Asset ID	OT-PLC-001
Function	Boiler feedwater control
Owner	Plant Operations
Manufacturer / model	Approved controller model
Firmware / OS	Validated version

Location	Plant 2 - Control Cabinet B
Zone	Basic Process Control
Criticality	Critical
Safety impact	Potential process trip and equipment damage
Network dependencies	HMI, historian, engineering workstation
Remote access	Vendor through approved jump host only
Backup	Logic backup verified quarterly
Support status	Supported through 2028
Last review	2026-07-18

Sample OT risk statement

Risk: A shared vendor account with persistent remote access could be compromised and used to modify controller logic. Impact: Loss of control, unsafe process conditions, production interruption, and equipment damage. Treatment: Replace the shared account with named identities, MFA, time-limited approval, monitored jump-host sessions, controller change alerts, and quarterly access review.

24. Glossary and official references

Term	Definition
OT	Technology that monitors or controls physical processes, devices, and infrastructure.
ICS	Industrial control systems used to control industrial processes.
SCADA	Supervisory control and data acquisition for distributed monitoring and control.
PLC	Programmable logic controller.
HMI	Human-machine interface used by operators.
SIS	Safety instrumented system designed to move a process to a safe state.
Zone	Group of assets with common security requirements.
Conduit	Controlled communication path between zones.
Historian	System that stores time-series process data.
Engineering workstation	System used to configure and program industrial assets.

Official references

- NIST SP 800-82 Rev. 3 - Guide to Operational Technology Security: <https://csrc.nist.gov/pubs/sp/800/82/r3/final>
- NIST SP 800-82 Rev. 4 - Pre-Draft Call for Comments: <https://csrc.nist.gov/pubs/sp/800/82/r4/iprd>
- NIST Cybersecurity Framework 2.0: <https://www.nist.gov/cyberframework>
- ISA/IEC 62443 Series of Standards: <https://www.isa.org/standards-and-publications/isa-standards/isa-iec-62443-series-of-standards>
- MITRE ATT&CK for ICS: <https://attack.mitre.org/matrices/ics/>

- CISA Cross-Sector Cybersecurity Performance Goals: <https://www.cisa.gov/cross-sector-cybersecurity-performance-goals>
- CISA Industrial Control Systems Resources: <https://www.cisa.gov/topics/industrial-control-systems>

License

Copyright © 2026 Alberto (Al) Leiva. Licensed under CC BY-NC-SA 4.0.